

Incident Analysis of the Linuxsys Cryptominer Campaign

Exploitation of CVE-2021-41773 in
Apache HTTP Server 2.4.49

Table of Contents

1	Executive Summary	1
2	Scope and Key Facts	2
2.1	Scope Statement	2
2.2	Key Facts	2
3	Incident Timeline	3
4	Technical Analysis and Root Cause	4
4.1	Root Cause	4
4.2	Exploitation Conditions	4
4.3	High-Level Attack Path	4
5	Impact	5
5.1	Technical Impact: CIA	5
5.2	Business Impact and Uncertainty	5
6	CVSS and MITRE ATT&CK Analysis	6
6.1	Published and Alternative CVSS Assessments	6
6.2	MITRE ATT&CK Mapping	7
7	Mitigations and Residual Risk	8
7.1	Prioritised Response	8
7.2	Residual Risk and Verification	8
8	Sources and Source Criticism	9
8.1	Agreement, Differences and Weighting	9
9	Final Assessment and Summary	10
	References & Sources	11
A	Vulnerable Apache Path-Normalisation Logic	12

1 Executive Summary

In July 2025, VulnCheck reported a renewed exploitation of CVE-2021-41773 which is a path traversal vulnerability affecting Apache HTTP Server 2.4.49, as part of the Linuxsys cryptomining campaign. Under vulnerable configurations, the flaw can expose files outside the intended web root and, when CGI is enabled, allow remote command execution. Campaign reporting documented repeated exploitation attempts, shell based payload retrieval and execution of a cryptocurrency miner on compromised Linux systems. [\[1, 2, 3\]](#)

CVE-2021-41773 was patched in 2021, but the Linuxsys activity shows that old and unpatched Apache systems can still be targeted years later. The vulnerability also remains listed in CISA's Known Exploited Vulnerabilities Catalog. Affected organisations should upgrade vulnerable Apache installations, review directory and CGI configuration, and investigate previously exposed systems for signs of compromise. [\[2, 4, 8\]](#)

Campaign at a Glance



Taking a closer look at the numbers

VulnCheck observed roughly 400 active workers in the mining wallet and described them as victims, but this is a campaign level estimate rather than a count of hosts proven to have been compromised specifically through CVE-2021-41773, mainly because the same campaign was associated with several other vulnerabilities.

The five staging sites and single exploitation source IP describe the iteration observed by VulnCheck in July 2025 and not the complete infrastructure of the campaign. [\[1\]](#)

2 Scope and Key Facts

2.1 Scope Statement

In scope- This report examines the July 2025 Linuxsys cryptominer activity, focusing on exploitation of CVE-2021-41773 against Apache HTTP Server 2.4.49. The analysis covers the vulnerable attack surface, path traversal, CGI related command execution, payload retrieval and local miner execution, together with technical impact, business impact, ATT&CK mapping and remediation.

Out of scope- Privilege escalation, lateral movement, SSH activity, brute-force attacks, propagation between hosts and Windows specific payload execution, as well as PoC testing are excluded.

2.2 Key Facts

Item	Finding
Product	Apache HTTP Server
Primary vulnerability	CVE-2021-41773
Affected version	Apache HTTP Server 2.4.49 only; the first fix in 2.4.50 was incomplete and tracked separately as CVE-2021-42013. [2, 3]
Weakness class	CWE-22: Improper Limitation of a Pathname to a Restricted Directory (Path Traversal). [3]
Published CVSS	NIST/NVD: 9.8 Critical, CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H. CISA-ADP also publishes a 7.5 High interpretation with confidentiality impact only. [3]
Primary attack surface	Internet facing or otherwise network accessible Apache HTTP service running the vulnerable version.
Higher-impact condition	Files outside the intended directory must be accessible to the Apache process, and CGI must be enabled for the vulnerability to lead to remote command execution. [2, 5]
Observed 2025 payload	Linuxsys cryptocurrency miner delivered through shell based download and execution activity. [1]
Current status	The flaw has been patched since 2021, but CISA lists it in the Known Exploited Vulnerabilities Catalog and exploitation was still observed in 2025. [4, 1]

3 Incident Timeline



Date	Event
16 Sep 2021	Apache HTTP Server 2.4.49 was released. The vulnerable path normalisation change was present in this version. [2]
29 Sep 2021	CVE-2021-41773 was reported to the Apache security team. [2]
4 Oct 2021	Apache 2.4.50 was released with the initial fix for CVE-2021-41773. [2]
7 Oct 2021	Apache disclosed that the 2.4.50 fix was incomplete. CVE-2021-42013 tracked the remaining issue, and Apache 2.4.51 was released with the corrected fix. [2, 5]
3 Nov 2021	CISA added CVE-2021-41773 to its Known Exploited Vulnerabilities Catalog. [4]
1–16 Jul 2025	VulnCheck observed repeated attempts to exploit an Apache 2.4.49 canary and deploy Linuxsys. [1]
17 Jul 2025	VulnCheck published its analysis of the Linuxsys campaign. Other security sources also reported on the activity during the same period. [1, 7, 11]

The 2025 campaign occurred almost four years after the vulnerability had been patched.

4 Technical Analysis and Root Cause

4.1 Root Cause

The root cause of CVE-2021-41773 was a flaw in Apache HTTP Server 2.4.49's URL path normalisation logic. Rapid7 identified the vulnerable behaviour in the `ap_normalize_path()` function in `server/util.c`, where specially encoded dot segments such as `.%2e/` could bypass the intended directory traversal checks. This allowed crafted requests to evade normal `../` protection under vulnerable configurations. [5]

The weakness is classified as **CWE-22: Path Traversal**. If files outside the intended web root were accessible to the Apache process, the flaw could expose local files. If CGI was also enabled and an executable shell could be reached, the same weakness could lead to remote command execution. [2, 3, 5]

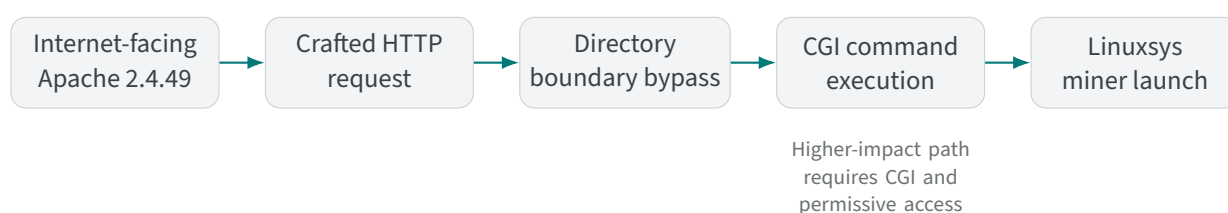
A relevant excerpt of the vulnerable `ap_normalize_path()` logic is included in Appendix A.

4.2 Exploitation Conditions

Running Apache 2.4.49 alone did not guarantee the same level of impact on every system. Successful path traversal depended on directory restrictions and the permissions of the Apache process, while remote command execution required CGI functionality to be accessible. [2, 5]

These conditions were important in the Linuxsys campaign because the vulnerability was used as an entry mechanism and not as the attacker's final objective. Once command execution was available, the campaign used shell commands and standard Linux utilities such as `curl` or `wget` to retrieve and prepare the Linuxsys mining payload. [1]

4.3 High-Level Attack Path



Observed attack path

VulnCheck observed shell based download commands being used after exploitation to retrieve campaign files, make the miner executable and launch it on the affected Linux host. This links the Apache vulnerability to the Linuxsys payload delivery stage observed in the campaign. [1]

5 Impact

5.1 Technical Impact: CIA

Confidentiality

Confidentiality is affected because the path traversal flaw can allow an attacker to read files outside Apache's intended web root. If the Apache process has permission to read those files, their contents may be returned through a crafted HTTP request without authorisation. This creates a risk of exposing local system files or other sensitive information accessible to the web server process. [2, 3]

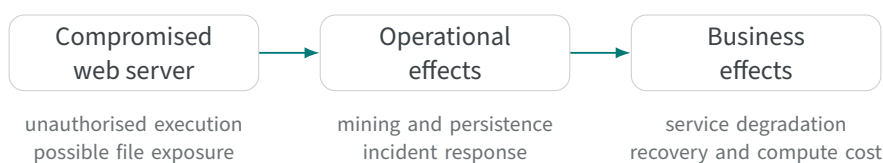
Integrity

Integrity is affected because the attacker was able to make unauthorised changes to the compromised system. In the Linuxsys campaign, shell commands were used to download scripts and the miner, change file permissions, execute the payload and establish cron based persistence. These actions modified the system beyond its intended state and represents a direct integrity impact. [1]

Availability

Availability can be affected because cryptocurrency mining consumes CPU and other system resources that would normally be available to legitimate services. This can reduce system performance, slow applications and increase resource usage on the compromised host. However, the reviewed campaign sources do not provide confirmed figures for service outages or complete loss of availability. [1, 7, 11]

5.2 Business Impact and Uncertainty



For an affected organisation Linuxsys can cause unauthorised resource use, degraded performance and additional investigation and recovery effort. Cron based persistence means that terminating the miner alone may not remove the compromise, while permissive Apache configurations can also expose readable local files. [1, 2]

The exact business impact depends on factors such as server configuration, system permissions and how long the infection remains active. The reviewed sources do not provide confirmed figures for campaign-wide downtime, financial loss or data theft, so those effects cannot be properly established for this incident.

6 CVSS and MITRE ATT&CK Analysis

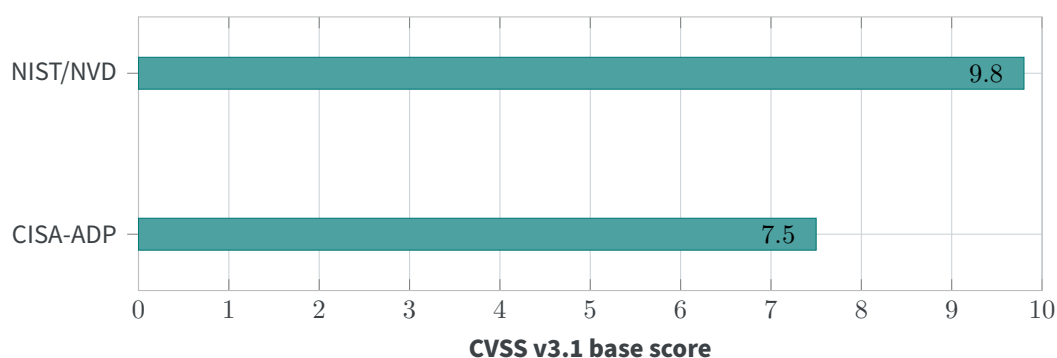
6.1 Published and Alternative CVSS Assessments

NVD currently displays a NIST CVSS v3.1 base score of **9.8 Critical**. [3] The published vector is:

```
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
```

The same NVD page also displays a **7.5 High** CISA-ADP assessment using:

```
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
```



Both assessments agree that the vulnerability can be exploited remotely, without authentication, with low attack complexity and without user interaction. The difference is in the expected impact. The 7.5 score represents a confidentiality only scenario, while the 9.8 score includes high impact to confidentiality, integrity and availability.

Assessment

For the Linuxsys campaign, the observed shell execution supports integrity impact because the attacker was able to download and execute files on the compromised host. Mining activity can also affect availability through increased resource usage. However, the campaign sources do not provide evidence that every affected system experienced the full CIA impact represented by the 9.8 score.

6.2 MITRE ATT&CK Mapping

T1190 - Exploit Public-Facing Application

Tactic: Initial Access

T1190 is the strongest ATT&CK mapping for the initial compromise. The Linuxsys campaign targeted an internet facing Apache HTTP Server and exploited CVE-2021-41773 to gain access through the vulnerable web service. This corresponds closely to MITRE's description of adversaries exploiting weaknesses in public facing applications to establish initial access. [9, 1]

The mapping is supported by the observed exploitation of an Apache 2.4.49 canary during the July 2025 campaign and by the vendor documented vulnerability in the exposed HTTP service. The technique therefore describes the attack method rather than merely the presence of a vulnerable application. [1, 2]

Mapping limitation. T1190 does not by itself describe the later payload download, miner execution or persistence.

T1059.004 - Command and Scripting Interpreter: Unix Shell

Tactic: Execution

T1059.004 is appropriate for the execution stage because the campaign used shell based commands on Linux systems after exploitation. VulnCheck documents command line activity involving tools such as `curl` or `wget` to retrieve a script and payload, make the miner executable and launch it on the compromised host. [10, 1]

This is more precise than using only the parent technique T1059 because the reported activity specifically involved a Unix/Linux shell environment. It also avoids over mapping the behaviour to discovery or lateral movement techniques that are not supported by the reviewed incident evidence.

Mapping limitation. The available sources support shell execution, but they do not establish persistence, credential access, privilege escalation or lateral movement as part of the scoped incident.

Why the mapping is deliberately narrow

The ATT&CK mapping focuses only on behaviour directly supported by the incident sources. T1190 captures exploitation of the exposed Apache service, while T1059.004 captures the subsequent shell based execution. Additional ATT&CK techniques could theoretically apply to later malware behaviour, but including them without clear evidence would make the mapping more speculative than source based.

7 Mitigations and Residual Risk

7.1 Prioritised Response

01 - Immediate

Upgrade Apache 2.4.49 and 2.4.50 systems to a currently supported fixed release. Identify Internet-facing affected hosts, investigate signs of exploitation, restore restrictive directory controls and disable unnecessary CGI functionality [2, 4, 8]

02 - Short-Term

Hunt for Linuxsys indicators published by VulnCheck, including 103.193.177.152, repositorylinux.org, known staging hosts and malware hashes. Check affected systems for linuxsys, linux.sh, config.sh and cron.sh, including cron based persistence. [1]

03 - Longer-Term

Maintain an inventory of internet facing services, perform regular vulnerability scans and define patching timelines. WAF protection and Snort IDS/IPS rules, such as Cisco Talos SID 58276, can provide additional detection or filtering. Monitoring should also include suspicious outbound connections, unexpected child processes and sustained resource usage. [6, 8]

7.2 Residual Risk and Verification

Patching removes the vulnerable Apache path normalisation behaviour, but it does not remove malware or persistence that may already exist on the host. After upgrading, affected systems should therefore be checked for suspicious processes, files, cron jobs and network activity linked to the Linuxsys campaign. [1, 2]

Later it was discovered that indicator based blocking also has limitations. VulnCheck observed the miner and configuration files being distributed from compromised legitimate websites with valid TLS certificates, reducing the value of relying only on domain reputation or certificate trust. These staging systems can also change over time, so published IoC's are most useful for retrospective hunting and investigation rather than as a permanent standalone control. [1]

Control hierarchy

Patching removes the vulnerability, hardening reduces exposure, and detection controls help identify exploitation attempts. IOC hunting and host inspection address the question of whether the system has already been compromised. [1, 2, 6]

8 Sources and Source Criticism

When analysing this incident, multiple sources are needed because each contributes a different type of evidence. Vendor advisories are strongest for affected versions and fixes, while campaign research helps explain observed attacker behaviour. Framework and detection sources are then useful for understanding techniques, mitigations and defensive controls.

Source	Role	Strength	Limitation
Apache [2]	Vendor advisory	Primary source for affected versions, release dates, configuration conditions and fixes.	Focuses on the vulnerability itself rather than the later Linuxsys campaign.
NVD / CISA [3, 4]	Government / vulnerability data	Strong for CVE metadata, CWE, severity data and known exploitation status.	CVSS scores describe vulnerability severity, not the exact impact of this campaign.
Rapid7 [5]	Independent technical analysis	Explains root cause and the relationship between traversal, CGI and RCE in technical detail.	Shows what is technically possible but not what happened on every host.
VulnCheck [1]	Campaign research	Primary source for the July 2025 Linuxsys campaign, including exploitation attempts, payload behaviour and indicators.	Campaign telemetry does not confirm the exact number of hosts compromised through this CVE.
LinuxSecurity / Intertec [7, 11]	News / advisory context	Corroborates previous reporting of Linuxsys deployment and operational impact.	Secondary reporting should be weighted below direct source campaign data.
Cisco Talos / Snort [6]	Detection reference	Provides a concrete Snort rule for detecting Apache directory-traversal attempts tied to the CVEs.	Signature-based detection is limited to traffic that matches the rule and may not detect modified or evasive attack patterns.
Huntress [8]	Mitigation guidance	Useful for remediation, monitoring and defence-in-depth recommendations.	It is retrospective guidance published after the campaign and is more useful for mitigation than for establishing what happened during the July 2025 incident.
MITRE ATT&CK [9, 10]	Framework reference	Provides authoritative definitions for ATT&CK techniques such as T1190 and T1059.004, helping map the observed behaviour to recognised adversary techniques.	It is a classification framework and does not provide incident-specific evidence that a technique occurred in the Linuxsys campaign.

8.1 Agreement, Differences and Weighting

Apache, NVD and Rapid7 agree on the main technical details of CVE-2021-41773, including the affected version, path traversal behaviour and the possibility of remote command execution when CGI is exposed. [2,3,5]

For the July 2025 Linuxsys activity, VulnCheck is given the most weight because it provides direct campaign observations, including exploitation attempts, payload delivery and indicators. Other sources are used mainly to support vulnerability details, detection and mitigation.

The main difference between the sources is the CVSS assessment. NVD shows both the NIST 9.8 score and the CISA-ADP 7.5 score, which reflect different assumptions about impact. These are treated as different severity scenarios rather than exact measurements of the impact on every affected system. [3]

9 Final Assessment and Summary

CVE-2021-41773 is a path traversal vulnerability affecting Apache HTTP Server 2.4.49. Apache, NVD and Rapid7 document that the flaw can expose files outside the intended web root when directory protections are insufficient, and that CGI-enabled configurations can also allow remote command execution. VulnCheck later documented exploitation attempts during the July 2025 Linuxsys campaign, where the vulnerability was used to deliver and execute the cryptomining payload. [2, 5, 1]

Conditional or uncertain - The actual impact varied depending on the configuration of the affected server. File permissions, CGI exposure, the privileges of the Apache service account and the duration of the infection all influenced what an attacker could achieve. The reviewed sources therefore do not support assuming that every vulnerable system experienced the same level of compromise or disruption.

Recommended decision - The priority is to upgrade affected Apache installations, remove unsupported versions from internet exposure, review directory and CGI configuration, and investigate previously exposed systems for signs of compromise. The Linuxsys campaign also shows the importance of identifying old public facing systems before they remain exposed long enough to become useful targets for attackers.

Decision summary

Patch first! Then verify exposure, investigate compromise, harden the configuration and maintain asset visibility. The 2025 campaign shows that a vulnerability disclosed and patched in 2021 can remain operationally useful to attackers when vulnerable internet facing systems persist.

References & Sources

- [1] Jacob Baines, VulnCheck. *The Linuxsys Cryptominer*. Published 17 July 2025.
<https://www.vulncheck.com/blog/linuxsys-cryptominer>
- [2] Apache Software Foundation. *Apache HTTP Server 2.4 Vulnerabilities – CVE-2021-41773 and CVE-2021-42013*. CVE-2021-41773 reported 29 September 2021; fix released 4 October 2021. CVE-2021-42013 fix released 7 October 2021.
https://httpd.apache.org/security/vulnerabilities_24.html
- [3] National Institute of Standards and Technology, National Vulnerability Database. *CVE-2021-41773 Detail*. Published October 2021. Accessed 21 September 2026.
<https://nvd.nist.gov/vuln/detail/CVE-2021-41773>
- [4] Cybersecurity and Infrastructure Security Agency. *Known Exploited Vulnerabilities Catalog – CVE-2021-41773*. Added to the KEV Catalog 3 November 2021. Accessed 21 September 2026.
<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [5] Rapid7 Threat Research. *Rapid7 Analysis: CVE-2021-41773*. Published October 2021.
<https://www.rapid7.com/blog/post/ra-cve-2021-41773-analysis/>
- [6] Cisco Talos Intelligence Group / Snort. *Rule Document 1:58276 – Apache HTTP Server httpd Directory Traversal Attempt*. Publication date not stated. Accessed 21 September 2026.
https://www.snort.org/rule_docs/1-58276
- [7] Brittany Day, LinuxSecurity. *Hackers Are Milking an Old Apache Flaw to Deploy Linuxsys Cryptominer*. Published 21 July 2025.
<https://linuxsecurity.com/news/hackscracks/hackers-exploit-old-apache-flaw-deploy-linuxsys-cryptominer>
- [8] Lizzie Danielson, Huntress. *CVE-2021-41773 Vulnerability: Analysis, Impact, Mitigation*. Published 21 November 2025.
<https://www.huntress.com/threat-library/vulnerabilities/cve-2021-41773>
- [9] MITRE ATT&CK. *T1190 – Exploit Public-Facing Application*. Created 18 April 2018; last modified 12 May 2026.
<https://attack.mitre.org/techniques/T1190/>
- [10] MITRE ATT&CK. *T1059.004 – Command and Scripting Interpreter: Unix Shell*. Created 9 March 2020; last modified 12 May 2026.
<https://attack.mitre.org/techniques/T1059/004/>
- [11] Intertec Systems. *Cryptocurrency Miner Installed via Apache HTTP Server Path Traversal Flaw*. Publication date not stated. Accessed 21 September 2026.
<https://www.intertecsystems.com/threat-report-and-advisories/cryptocurrency-miner-installed-via-apache-http-server-path-traversal-flaw>

A Vulnerable Apache Path-Normalisation Logic

The vulnerability in Apache HTTP Server 2.4.49 was connected to the way requested paths were normalised before processing. Rapid7 traced the issue to the `ap_normalize_path()` function in `server/util.c`. In affected configurations, an encoded sequence such as `.%2e/` could avoid the expected directory-traversal checks. [5]

The excerpt below shows the part of the function responsible for identifying and removing dot based path segments:

```
if (path[l] == '.') {  
  
    /* Remove ./ segments */  
    if (IS_SLASH_OR_NUL(path[l + 1])) {  
        l++;  
        if (path[l]) {  
            l++;  
        }  
        continue;  
    }  
  
    /* Remove /xx/./ segments */  
    if (path[l + 1] == '.' &&  
        IS_SLASH_OR_NUL(path[l + 2])) {  
  
        if (w > 1) {  
            do {  
                w--;  
            } while (w && !IS_SLASH(path[w - 1]));  
        }  
  
        l += 2;  
        if (path[l]) {  
            l++;  
        }  
        continue;  
    }  
}
```

The check expects a normal dot sequence when detecting traversal. Because an encoded value such as `.%2e` was not recognised as the second dot at this stage, a crafted path could bypass the intended `./` protection and move outside the expected directory boundary. [5]

In the Linuxsys campaign, CVE-2021-41773 was used as an initial entry point against exposed Apache 2.4.49 systems. After exploitation, shell commands retrieved and launched the Linuxsys cryptomining payload. The vulnerable path normalisation logic therefore enabled the first stage of the campaign. [1, 5]

The excerpt is included to support the root cause analysis and identify where the path normalisation failure occurred. It is not an exploit demonstration.

Tools and Drafting Disclosure

LaTeX formatting, structure and language assistance was used during the preparation of this report with the support of an LLM.